DFIR WireShark Emotet 4

Riyad Alshehri

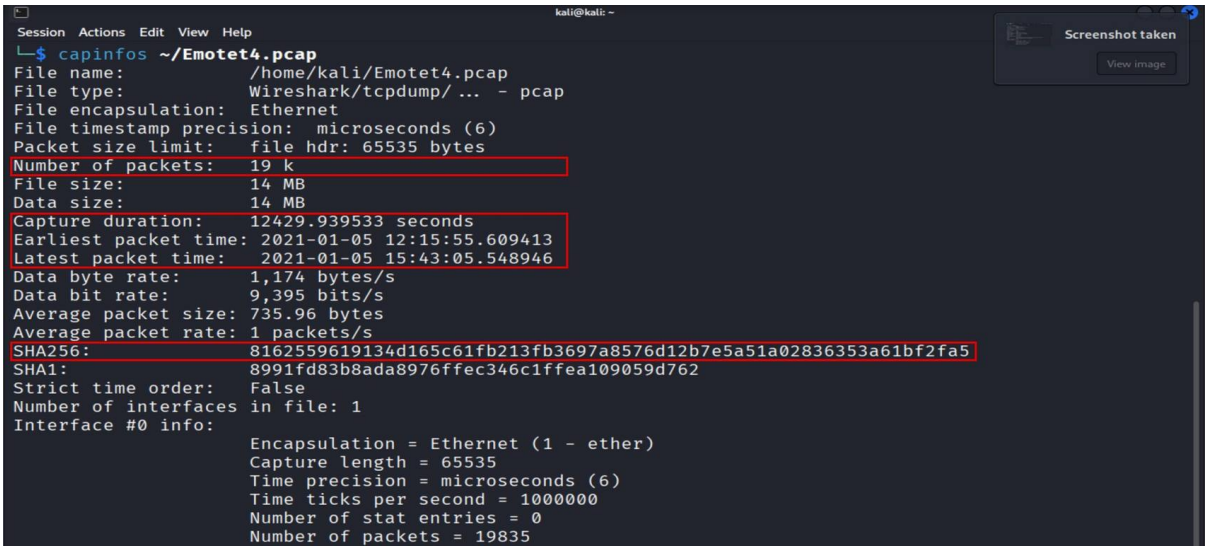
في هذا التاسك حللت ملف pcap فيه ترافيك جهاز مصاب ومشيت على نفس الترتيب: حفظ الدليل ثم الصورة العامة ثم هوية الضحية ثم DNS ثم HTTP وفي الاخير الملفات اللي نزلت.

1- حفظ الدليل

- نقلت الملف للكالي وطلعت الهاش وتأكدت انه نفس هاش الملف الاصلي.

- شغلت capinfos وطلع ان الملف فيه 19835 باكت ومدة التسجيل تقريبا 3 ساعات ونص.

- الوقت في الصورة بتوقيت الكالي والوقت الفعلي بتوقيت UTC من 17:15 الى 20:43 يوم 5 يناير 2021.



2- الصورة العامة

- فتحت Statistics ثم Conversations ثم تبويب TCP ورتبت المحادثات حسب الحجم.

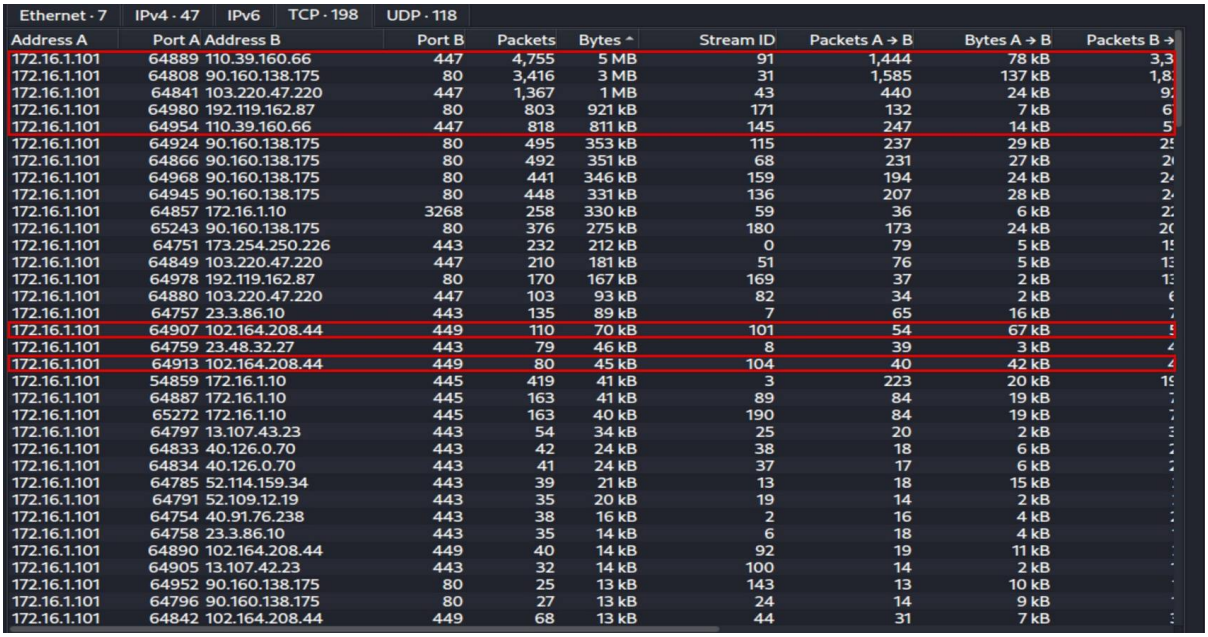
- الجهاز 172.16.1.101 موجود في كل المحادثات فهو الجهاز اللي بحقق فيه.

- اكبر محادثة كانت مع 110.39.160.66 على بورت 447 وحجمها 5 MB.

- بعدها 90.160.138.175 على بورت 80 وحجمها 3 MB وهذا الـ IP يتكرر في القائمة اكثر من مرة.

- وفيه محادثات مع 103.220.47.220 على بورت 447 و 102.164.208.44 على بورت 449.

- بورت 447 و 449 مو بورتات معروفة للتصفح عشان كذا حطيتها ضمن الاشياء المشبوهة.

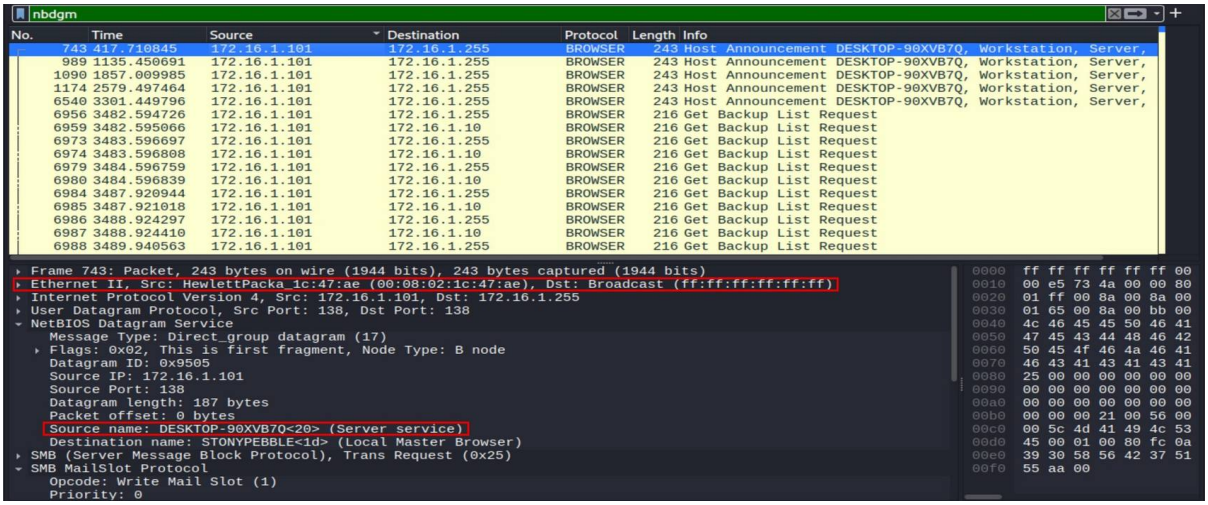


Ethernet · 7 | IPv4 · 47 | IPv6 | TCP · 198 | UDP · 118

Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B →
172.16.1.101	64889	110.39.160.66	447	4,755	5 MB	91	1,444	78 kB	3,3
172.16.1.101	64808	90.160.138.175	80	3,416	3 MB	31	1,585	137 kB	1,8
172.16.1.101	64841	103.220.47.220	447	1,367	1 MB	43	440	24 kB	9
172.16.1.101	64980	192.119.162.87	80	803	921 kB	171	132	7 kB	6
172.16.1.101	64954	110.39.160.66	447	818	811 kB	145	247	14 kB	5
172.16.1.101	64924	90.160.138.175	80	495	353 kB	115	237	29 kB	2
172.16.1.101	64866	90.160.138.175	80	492	351 kB	68	231	27 kB	2
172.16.1.101	64968	90.160.138.175	80	441	346 kB	159	194	24 kB	2
172.16.1.101	64945	90.160.138.175	80	448	331 kB	136	207	28 kB	2
172.16.1.101	64857	172.16.1.10	3268	258	330 kB	59	36	6 kB	2
172.16.1.101	65243	90.160.138.175	80	376	275 kB	180	173	24 kB	2
172.16.1.101	64751	173.254.250.226	443	232	212 kB	0	79	5 kB	1
172.16.1.101	64849	103.220.47.220	447	210	181 kB	51	76	5 kB	1
172.16.1.101	64978	192.119.162.87	80	170	167 kB	169	37	2 kB	1
172.16.1.101	64880	103.220.47.220	447	103	93 kB	82	34	2 kB	6
172.16.1.101	64757	23.3.86.10	443	135	89 kB	7	65	16 kB	7
172.16.1.101	64907	102.164.208.44	449	110	70 kB	101	54	67 kB	5
172.16.1.101	64759	23.48.32.27	443	79	46 kB	8	39	3 kB	4
172.16.1.101	64913	102.164.208.44	449	80	45 kB	104	40	42 kB	4
172.16.1.101	54859	172.16.1.10	445	419	41 kB	3	223	20 kB	1
172.16.1.101	64887	172.16.1.10	445	163	41 kB	89	84	19 kB	7
172.16.1.101	65272	172.16.1.10	445	163	40 kB	190	84	19 kB	7
172.16.1.101	64797	13.107.43.23	443	54	34 kB	25	20	2 kB	3
172.16.1.101	64833	40.126.0.70	443	42	24 kB	38	18	6 kB	2
172.16.1.101	64834	40.126.0.70	443	41	24 kB	37	17	6 kB	2
172.16.1.101	64785	52.114.159.34	443	39	21 kB	13	18	15 kB	2
172.16.1.101	64791	52.109.12.19	443	35	20 kB	19	14	2 kB	1
172.16.1.101	64754	40.91.76.238	443	38	16 kB	2	16	4 kB	2
172.16.1.101	64758	23.3.86.10	443	35	14 kB	6	18	4 kB	1
172.16.1.101	64890	102.164.208.44	449	40	14 kB	92	19	11 kB	1
172.16.1.101	64905	13.107.42.23	443	32	14 kB	100	14	2 kB	1
172.16.1.101	64952	90.160.138.175	80	25	13 kB	143	13	10 kB	1
172.16.1.101	64796	90.160.138.175	80	27	13 kB	24	14	9 kB	1
172.16.1.101	64842	102.164.208.44	449	68	13 kB	44	31	7 kB	3

3- هوية الضحية

- استخدمت فلتر nbdgm وطلع لي اسم الجهاز DESKTOP-90XVB7Q والماك 00:08:02:1c:47:ae.



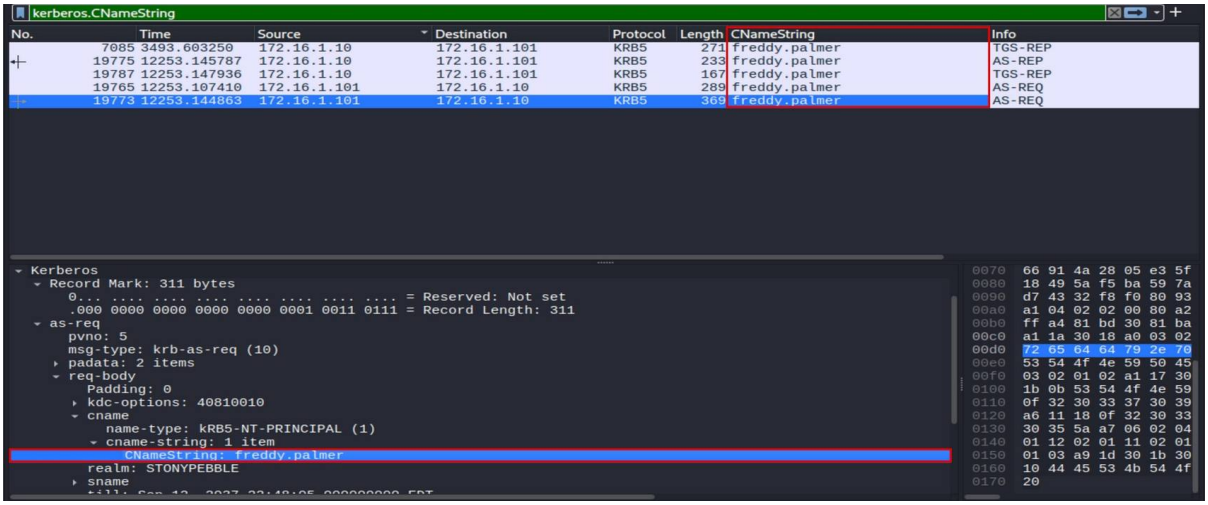
nbdgm

No.	Time	Source	Destination	Protocol	Length	Info
743	417.710845	172.16.1.101	172.16.1.255	BROWSER	243	Host Announcement DESKTOP-90XVB7Q, Workstation, Server,
989	1135.450691	172.16.1.101	172.16.1.255	BROWSER	243	Host Announcement DESKTOP-90XVB7Q, Workstation, Server,
1090	1857.009985	172.16.1.101	172.16.1.255	BROWSER	243	Host Announcement DESKTOP-90XVB7Q, Workstation, Server,
1174	2579.497464	172.16.1.101	172.16.1.255	BROWSER	243	Host Announcement DESKTOP-90XVB7Q, Workstation, Server,
6540	3301.449796	172.16.1.101	172.16.1.255	BROWSER	243	Host Announcement DESKTOP-90XVB7Q, Workstation, Server,
6956	3482.594726	172.16.1.101	172.16.1.255	BROWSER	216	Get Backup List Request
6959	3482.595066	172.16.1.101	172.16.1.10	BROWSER	216	Get Backup List Request
6973	3483.596697	172.16.1.101	172.16.1.255	BROWSER	216	Get Backup List Request
6974	3483.596808	172.16.1.101	172.16.1.10	BROWSER	216	Get Backup List Request
6979	3484.596759	172.16.1.101	172.16.1.255	BROWSER	216	Get Backup List Request
6980	3484.596839	172.16.1.101	172.16.1.10	BROWSER	216	Get Backup List Request
6984	3487.920944	172.16.1.101	172.16.1.255	BROWSER	216	Get Backup List Request
6985	3487.921018	172.16.1.101	172.16.1.10	BROWSER	216	Get Backup List Request
6986	3488.924297	172.16.1.101	172.16.1.255	BROWSER	216	Get Backup List Request
6987	3488.924410	172.16.1.101	172.16.1.10	BROWSER	216	Get Backup List Request
6988	3489.940563	172.16.1.101	172.16.1.255	BROWSER	216	Get Backup List Request

```
▸ Frame 743: Packet, 243 bytes on wire (1944 bits), 243 bytes captured (1944 bits)
▸ Ethernet II, Src: HewlettPacka_1c:47:ae (00:08:02:1c:47:ae), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
▸ Internet Protocol Version 4, Src: 172.16.1.101, Dst: 172.16.1.255
▸ User Datagram Protocol, Src Port: 138, Dst Port: 138
▾ NetBIOS Datagram Service
    Message Type: Direct_group datagram (17)
  ▸ Flags: 0x02, This is first fragment, Node Type: B node
    Datagram ID: 0x9505
    Source IP: 172.16.1.101
    Source Port: 138
    Datagram length: 187 bytes
    Packet offset: 0 bytes
    Source name: DESKTOP-90XVB7Q<20> (Server service)
    Destination name: STONYPEBBLE<1d> (Local Master Browser)
▸ SMB (Server Message Block Protocol), Trans Request (0x25)
▾ SMB MailSlot Protocol
    Opcode: Write Mail Slot (1)
    Priority: 0
```

```
0000  ff ff ff ff ff ff 00
0010  00 e5 73 4a 00 00 80
0020  01 ff 00 8a 00 8a 00
0030  01 65 00 8a 00 bb 00
0040  4c 46 45 45 50 46 41
0050  47 45 43 44 48 46 42
0060  50 45 4f 46 4a 46 41
0070  46 43 41 43 41 43 41
0080  25 00 00 00 00 00 00
0090  00 00 00 00 00 00 00
00a0  00 00 00 00 00 00 00
00b0  00 00 00 21 00 56 00
00c0  00 5c 4d 41 49 4c 53
00d0  45 00 01 00 80 fc 0a
00e0  39 30 58 56 42 37 51
00f0  55 aa 00
```

- واستخدمت فلتر kerberos.CNameString وطلع اليوزر freddy.palmer وطلع ان الـ DC هو 172.16.1.10.



يعني الضحية:

- IP: 172.16.1.101

- MAC: 00:08:02:1c:47:ae

- Hostname: DESKTOP-90XVB7Q

- User: freddy.palmer

- Domain: STONYPEBBLE

DNS -4

- استخدمت فلتر dns.flags.response == 0 عشان اعرض استعلامات DNS اللي طلعت من الجهاز بدون الردود وقارنت سلوكه قبل 18:03 وبعدها.

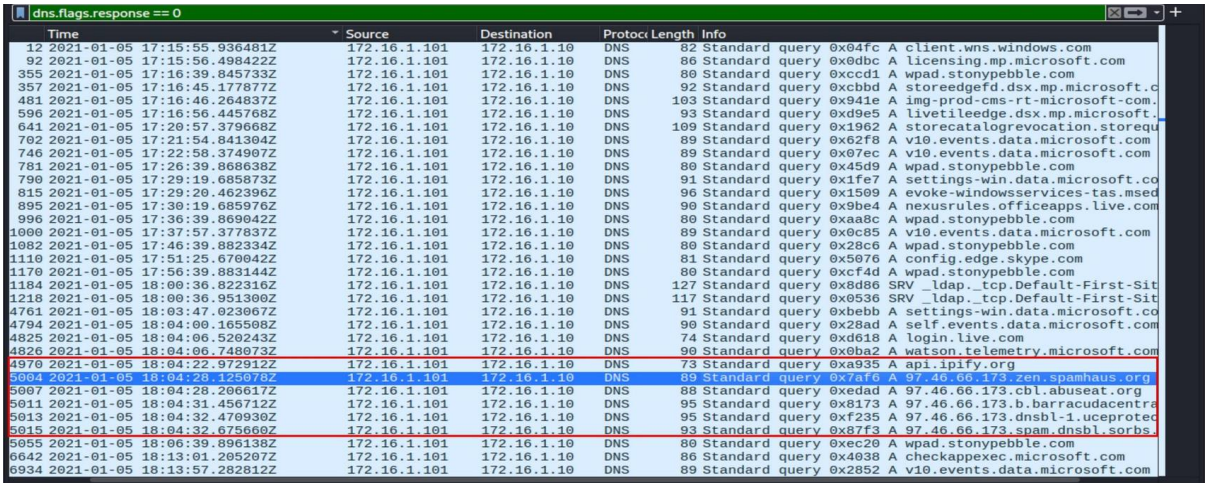
- قبل 18:03 كانت كل الاستعلامات لخدمات ويندوز ومايكروسوفت وللدومين الداخلي stonypebble.com وهذا ترافيك طبيعي.

- عند 18:04:22 ظهر استعلام جديد عن api.ipify.org وهذي خدمة ترجع الـ Public IP للجهاز يعني البرنامج يبي يعرف وش IP الشبكة اللي هو فيها على الانترنت.

- بعدها بست ثواني من 18:04:28 الى 18:04:32 ظهرت استعلامات لخمس قوائم سبام سوداء (DNSBL) وهي spamhaus و abuseat و barracudacentral و uceprotect و sorbs.

- كل الاستعلامات فيها نفس الـ IP مقلوب 97.46.66.173 وهذي طريقة الاستعلام في قوائم DNSBL يعني الـ Public IP الحقيقي للشبكة هو 173.66.46.97.

- يعني الجهاز عرف الـ IP العام للشبكة وبعدها فحص هل هو محظور كمرسل سبام وهذا سلوك ما يسويه مستخدم عادي ولا برنامج طبيعي وما ظهر الا بعد نشاط 18:03.



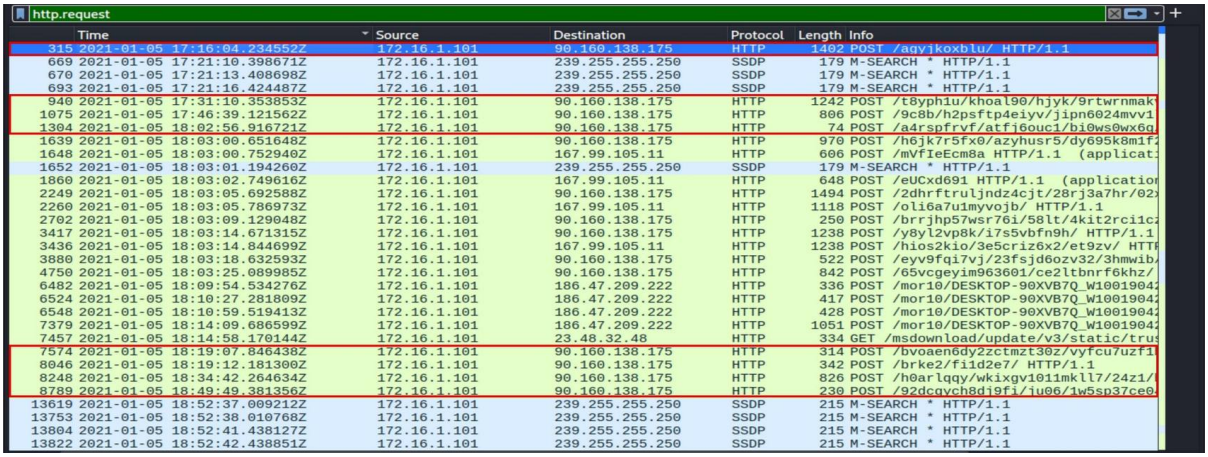
5- اتصالات C2

- استخدمت فلتر http.request وخليت الوقت بتوقيت UTC.

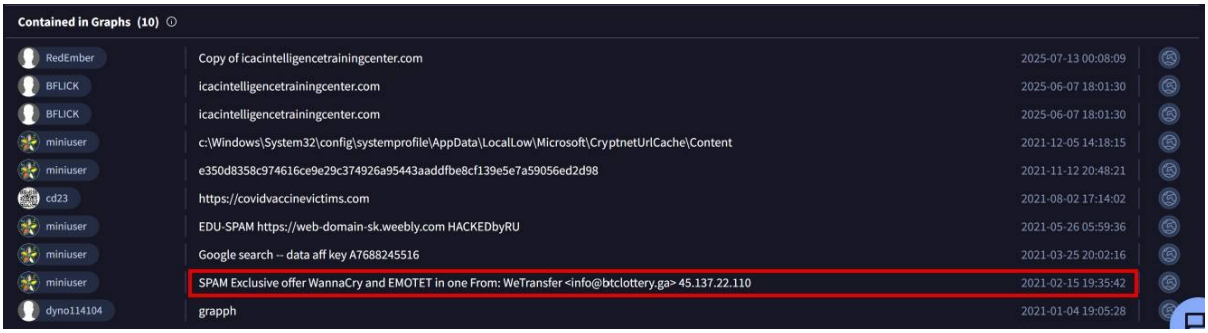
- لقيت الجهاز يرسل POST لـ 90.160.138.175 بشكل منتظم 17:16 ثم 17:31 ثم 17:46 ثم 18:02 يعني كل 15 دقيقة تقريبا.

- كل الطلبات POST والمسارات عشوائية وهذا نمط C2 Beaconing يعني البرنامج يتواصل مع سيرفر المهاجم كل فترة.

- وعند 18:03 صار عدد كبير من الطلبات خلال ثواني مع 90.160.138.175 و 167.99.105.11 وبعدها رجع النمط كل 15 دقيقة.



- حطيت 90.160.138.175 في VirusTotal وطلع 9/92 خبيث وفي Community مربوط بـ Emotet.

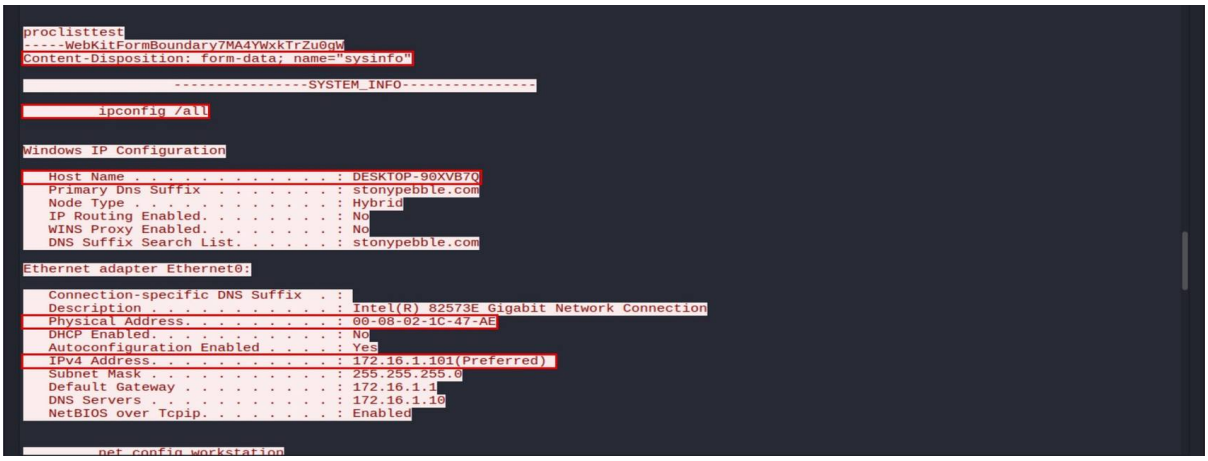


6- ارسال معلومات الجهاز

- من 18:09 صار الجهاز يرسل POST لـ IP 186.47.209.222 على بورت 443 بس بدون تشفير والمسار فيه اسم الجهاز DESKTOP-90XVB7Q.

- فتحت Follow HTTP Stream على الباكت 7379 ولقيت الجهاز ارسل قائمة البرامج الشغالة (proclist) ومعلومات النظام (sysinfo).

- في جزء sysinfo البرنامج شغل اوامر مثل ipconfig /all و net config workstation و nltest /domain_trusts وارسل نتايجها وفيها اسم الجهاز والـ MAC والـ IP.

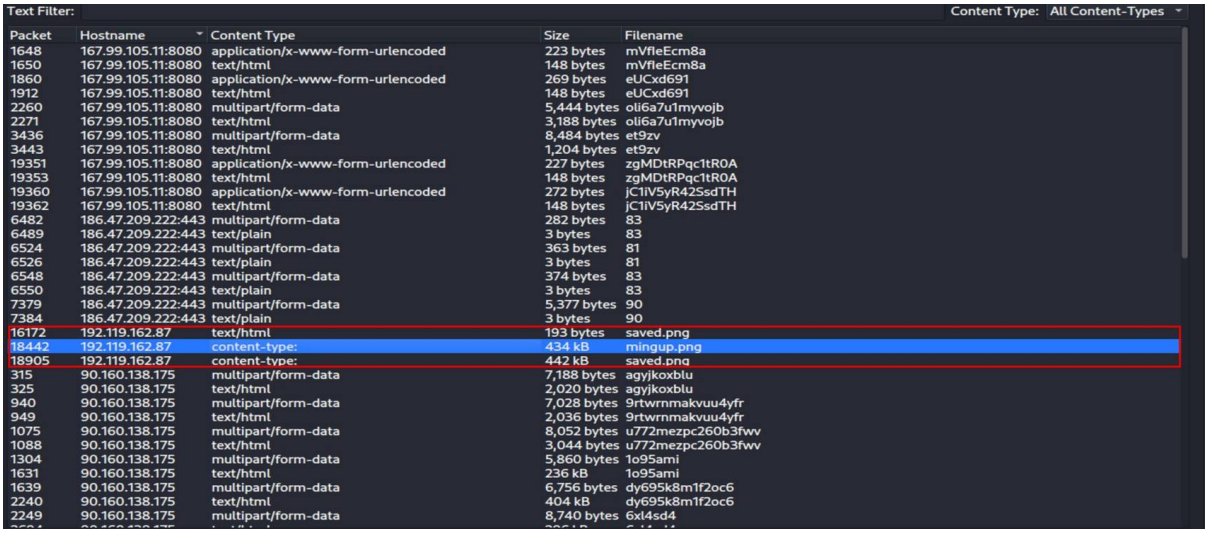


- وفي الباكت 6482 ارسل حقول formdata و billinfo و cardinfo يعني حاول يرسل بيانات نماذج وبطاقات بس الحقول كانت فاضية.



7- الملفات اللي نزلت

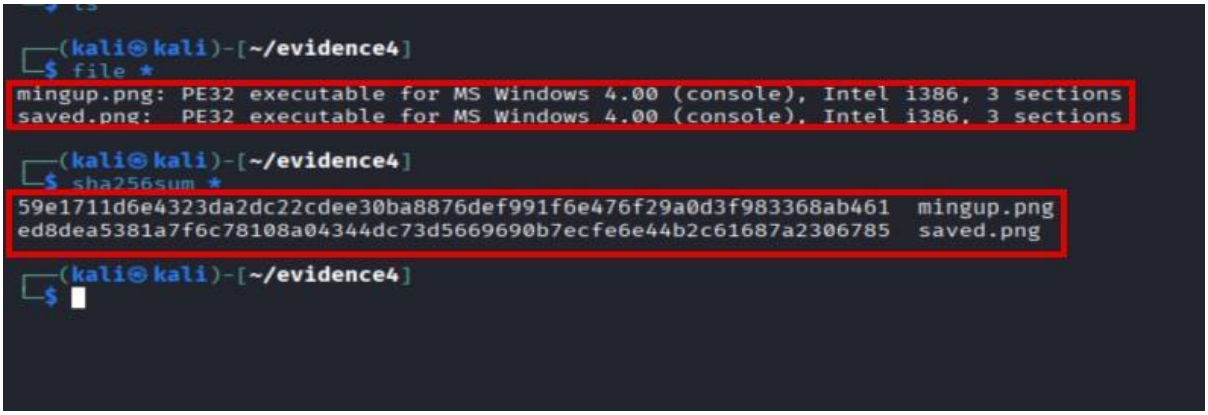
- من File ثم Export Objects ثم HTTP لقيت ملفين نزلوا من 192.119.162.87 باسم mingup.png و saved.png وحجمهم كبير ونوعهم مكتوب content-type: بس.



Text Filter: Content Type: All Content-Types

Packet	Hostname	Content Type	Size	Filename
1648	167.99.105.11:8080	application/x-www-form-urlencoded	223 bytes	mVfleEcm8a
1650	167.99.105.11:8080	text/html	148 bytes	mVfleEcm8a
1860	167.99.105.11:8080	application/x-www-form-urlencoded	269 bytes	eUCxd691
1912	167.99.105.11:8080	text/html	148 bytes	eUCxd691
2260	167.99.105.11:8080	multipart/form-data	5,444 bytes	oli6a7u1myvojb
2271	167.99.105.11:8080	text/html	3,188 bytes	oli6a7u1myvojb
3436	167.99.105.11:8080	multipart/form-data	8,484 bytes	et9zv
3443	167.99.105.11:8080	text/html	1,204 bytes	et9zv
19351	167.99.105.11:8080	application/x-www-form-urlencoded	227 bytes	zgMDtRPqc1tR0A
19353	167.99.105.11:8080	text/html	148 bytes	zgMDtRPqc1tR0A
19360	167.99.105.11:8080	application/x-www-form-urlencoded	272 bytes	jC1lV5yR42SsdTH
19362	167.99.105.11:8080	text/html	148 bytes	jC1lV5yR42SsdTH
6482	186.47.209.222:443	multipart/form-data	282 bytes	83
6489	186.47.209.222:443	text/plain	3 bytes	83
6524	186.47.209.222:443	multipart/form-data	363 bytes	81
6526	186.47.209.222:443	text/plain	3 bytes	81
6548	186.47.209.222:443	multipart/form-data	374 bytes	83
6550	186.47.209.222:443	text/plain	3 bytes	83
7379	186.47.209.222:443	multipart/form-data	5,377 bytes	90
7384	186.47.209.222:443	text/plain	3 bytes	90
16172	192.119.162.87	text/html	193 bytes	saved.png
18442	192.119.162.87	content-type:	434 kB	mingup.png
18905	192.119.162.87	content-type:	442 kB	saved.png
315	90.160.138.175	multipart/form-data	7,188 bytes	agyjkoxblu
325	90.160.138.175	text/html	2,020 bytes	agyjkoxblu
940	90.160.138.175	multipart/form-data	7,028 bytes	9rtwrnmakvuu4yfr
949	90.160.138.175	text/html	2,036 bytes	9rtwrnmakvuu4yfr
1075	90.160.138.175	multipart/form-data	8,052 bytes	u772mezpc260b3fwv
1088	90.160.138.175	text/html	3,044 bytes	u772mezpc260b3fwv
1304	90.160.138.175	multipart/form-data	5,860 bytes	1o95ami
1631	90.160.138.175	text/html	236 kB	1o95ami
1639	90.160.138.175	multipart/form-data	6,756 bytes	dy695k8m1f2oc6
2240	90.160.138.175	text/html	404 kB	dy695k8m1f2oc6
2249	90.160.138.175	multipart/form-data	8,740 bytes	6xl4sd4

- طلعتهم وشغلت عليهم file وطلع انهم PE32 executable يعني برامج ويندوز متنكرة بامتداد .png

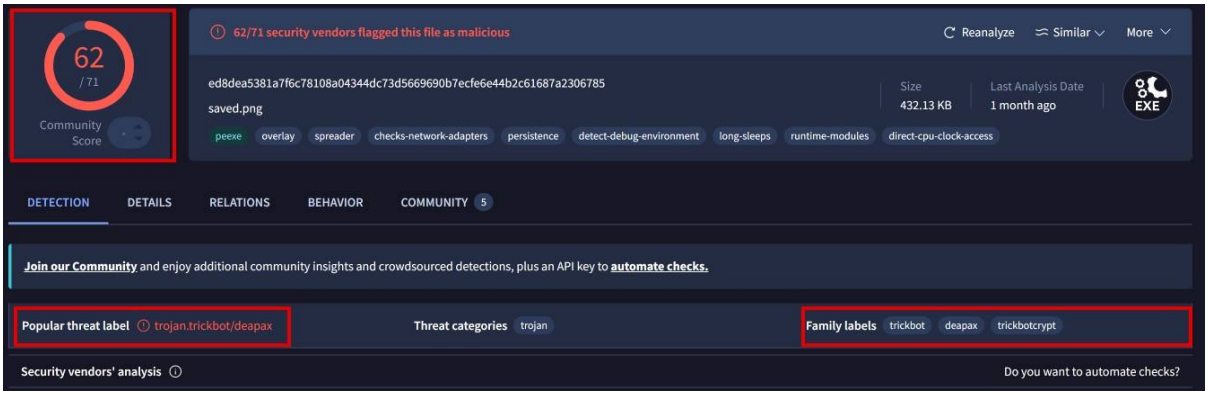


```
┌──(kali㉿kali)-[~/evidence4]
└─$ file *
mingup.png: PE32 executable for MS Windows 4.00 (console), Intel i386, 3 sections
saved.png:  PE32 executable for MS Windows 4.00 (console), Intel i386, 3 sections

┌──(kali㉿kali)-[~/evidence4]
└─$ sha256sum *
59e1711d6e4323da2dc22cdee30ba8876def991f6e476f29a0d3f983368ab461  mingup.png
ed8dea5381a7f6c78108a04344dc73d5669690b7ecfe6e44b2c61687a2306785  saved.png

┌──(kali㉿kali)-[~/evidence4]
└─$
```

- حطيت الهاش في VirusTotal وطلع saved.png 62/71 و mingup.png 55/67 والاثنين TrickBot.



62 / 71 — Community Score

62/71 security vendors flagged this file as malicious

Reanalyze | Similar | More

ed8dea5381a7f6c78108a04344dc73d5669690b7ecfe6e44b2c61687a2306785

saved.png

Size: 432.13 KB | Last Analysis Date: 1 month ago | EXE

peexe | overlay | spreader | checks-network-adapters | persistence | detect-debug-environment | long-sleeps | runtime-modules | direct-cpu-clock-access

DETECTION | DETAILS | RELATIONS | BEHAVIOR | COMMUNITY 5

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label: trojan.trickbot/deapax | Threat categories: trojan | Family labels: trickbot | deapax | trickbotcrypt

Security vendors' analysis | Do you want to automate checks?

- وفي صفحة الملف في VirusTotal ضمن Contacted IP addresses لقيت 102.164.208.44 وهو نفس الـ IP اللي شفته على بورت 449.

- و 110.39.160.66 اللي على بورت 447 مذكور في VirusTotal Community ضمن قائمة Trickbot IOCs.



الخلاصة

الجهاز DESKTOP-90XVB7Q حق المستخدم freddy.palmer كان مصاب بـ Emotet من بداية التسجيل ويتصل بسيرفراته كل 15 دقيقة. عند 18:03 صار نشاط مفاجئ مع سيرفرات C2 وبعدها مباشرة بدأ يفحص الـ Public IP في قوائم السبام ويرسل معلومات الجهاز وقائمة البرامج لسيرفر ثاني وحاول يسرق بيانات البطاقات بس الحقول كانت فاضية. وفيه اتصالات مع سيرفرات TrickBot على بورت 447 و449 وفي الاخير نزل الجهاز ملفين TrickBot متنكرين بامتداد png.

التسلسل الزمني (UTC):

- 17:16 بداية اتصالات Emotet كل 15 دقيقة مع 90.160.138.175
- 18:03 نشاط مفاجئ مع سيرفرات C2 90.160.138.175 و 167.99.105.11
- 18:04 اول اتصال مع 102.164.208.44 على بورت 449 وفحص الـ Public IP في قوائم السبام
- 18:09 بداية ارسال معلومات الجهاز لـ 186.47.209.222
- 18:50 اتصال مع 110.39.160.66 على بورت 447
- 20:17 نزول mingup.png و saved.png من 192.119.162.87
- 20:41 اخر اتصال Emotet في التسجيل

IOCs

- 90.160.138.175 بورت 80 سيرفر Emotet
- 167.99.105.11 بورت 8080 سيرفر C2 بنفس اسلوب 90.160.138.175
- 186.47.209.222 بورت 443 يستقبل معلومات الجهاز
- 102.164.208.44 بورت 449 سيرفر TrickBot
- 110.39.160.66 بورت 447 سيرفر TrickBot
- 192.119.162.87 بورت 80 نزلت منه ملفات TrickBot
- mingup.png SHA256: 59e1711d6e4323da2dc22cdee30ba8876def991f6e476f29a0d3f983368ab461

- saved.png SHA256: ed8dea5381a7f6c78108a04344dc73d5669690b7ecfe6e44b2c61687a2306785

التوصيات

- عزل الجهاز 172.16.1.101 عن الشبكة.
- حظر الـ IP المذكورة في الـ IOCs على الفايروول.
- تغيير باسورد اليوزر freddy.palmer.
- فحص باقي اجهزة الشبكة بنفس المؤشرات.
- مراقبة اي اتصال خارجي على بورت 447 و449 لأنها مو بورتات طبيعية.